MAJOR PROJECT

Phishing Awareness Simulation Using Social Engineering Techniques

Submitted by

Ananta Pratap

1. Introduction

The threat of cybersecurity has grown tremendously owing to the blistering development of online communication and online services. These threats have seen phishing attacks being the most prevalent and harmful types of cybercrime. Phishing is a form of social engineering attack where criminals aim to deceive people into disclosing sensitive data like passwords, financial or personal information by impersonating a trusted party.

The phishing is usually done via emails, messages or websites which seem to be legitimate to the unsuspecting user. Attackers tend to generate a feeling of urgency or fear to coerce victims to clicking malicious links or providing confidential information. As an illustration, the users might get emails saying that their account has been hacked and they should act immediately to confirm their identity.

Phishing attacks are highly effective as they are based on manipulation of the human psyche and not the technical weaknesses. Even the well-secured systems may be breached, but they can be compromised in case the users do not realize that they might give their credentials to the attackers.

The given project is devoted to the simulation of the phishing situation under the controlled conditions to gain a more comprehensive idea of how this attack is structured and how people react to it. The project will involve designing a non-threatening phishing email and a fake logs page in order to establish how people respond to phishing attacks and what are the general conditions making people fall prey to phishing.

The outcome of this, as one of the simulations, can serve to emphasize the need to create awareness about cybersecurity and prove the usefulness of practical measures which individuals and organisations can implement to avoid phishing attacks.

Objectives

The key goals of this project are:

- To get familiar with the issue of phishing and the social engineering component of cybersecurity threats.
- In order to create and model a phishing email within a controlled and ethical setting.
- To develop a counterfeit login page as an example of how phishing sites resemble legitimate sites.
- To profile user behavior and gauge awareness about phishing attacks.
- To find the factors that expose users to phishing attacks.
- To investigate preventive strategies and measures that could be effective in the process of minimizing the risks of phishing.

3. Literature Review

3.1 Phishing Attacks

Phishing is a type of cyberattack, which is set to steal sensitive data by pretending to users that they are communicating with a legitimate entity. In order to win the trust of the victim, attackers tend to present themselves as reputable organizations (bank, social media, or government institutions).

Phishing is most often performed with the help of email messages with dangerous links or attachments. Such emails frequently serve to lead the users to the counterfeit websites that are made to appear like the real-life login pages. After the users type in their credentials, the attackers may steal and abuse the credentials.

Phishing can be listed as one of the most efficient methods of cyberattack, as the type of attack is focused on human traits, and not on technological flaws. Phishing is a problem that affects many users as the messages are believable and they make them feel like they are in a rush.

3.2 Social Engineering Cybersecurity

Cybercriminals employ social engineering to control people to provide confidential information or undertake activities that undermine security. Attackers do not attack computer systems directly but rather, use human psychology to attain their objectives.

Typical social engineering attacks are:

- Creating urgency or fear
- Faking the role of authority
- Exploiting curiosity
- Giving counterfeit rewards or incentives

Phishing is regarded as one of the most popular social engineering tricks since it enables its implementers to contact a high number of interested victims via online communication.

3.3 Types of Phishing Attacks

There are a number of different forms of phishing attacks that can be used by attackers basing on the target and the mode of attack

Email Phishing

This is the most widespread type of phishing where phishers send fraudulent emails demanding sensitive data.

Spear Phishing

In spear phishing, the malicious user or organization focuses on a given individual or organization to send personalized messages.

Whaling

The high profile victims of whaling attacks are usually executives/managers of an organization.

Clone Phishing

In clone phishing, the attackers copy valid emails and substitute the original links with bad ones.

3.4 Impact of Phishing Attacks

The consequences of phishing attacks may have severe consequences to individuals and organizations. Such attacks may lead to monetary loss, fraud, account hijacking and data violations.

Companies that fall victim to phishing attacks can also lose reputation and customers. Cybersecurity awareness and training have become the necessary measure to prevent the risk of such attacks due to the constant development of phishing methods.

4. Methodology

4.1 Research Approach

The current project is based on the design-based research framework and simulation-driven research to create a Zero Trust Architecture (ZTA) that fits the needs of enterprise security setting.

The methodology is oriented on the application of the principle of Never Trust, Always Verify according to which every user, every device, and network request will be verified and only after that an access will be provided. The study involves:

- Zero Trust principles analysis.
- Enterprise security architecture design.
- Installation of authentication and access control systems.
- Cyber threats simulation to determine effectiveness.

4.2. Zero Trust Architecture Design

Zero Trust framework in the proposed solution has the following components:

1. Identity Verification

All users who seek access are required to pass through an identity authentication process by means of secured access credentials and verification processes. Measures implemented: Multi-Factor Authentication (MFA) Checking identity by means of login credentials. Constant identification checks.

2. Role Based Access Control (RBAC)

Role-based access control is provided and permission is assigned to organizations according to the roles of the organisation and not per-user. Example:

Admin → Full system access Employee- The access of the department is restricted.

Guest → Restricted access This reduces illegal data leakage.

3. Micro-Segmentation

Enterprise networks are sub-divided into smaller areas of security to ensure that there is no lateral flow of attacks. Benefits: Limits breach impact Eliminates unauthorized internal penetration. Enhances network isolation

4. Encryption Mechanisms

The encryption methods are used to secure the data: HTTPS encryption (TLS) of data-in-transit. Safe channels of communication. Coded authentication requests.

4.3 Simulation Environment

Virtualization programs are used to create a virtual enterprise environment, including: VMware Virtual machine / Docker containers. Computerized staff and management models. Enterprise network model which is secure. The simulation is based on the real world enterprise-access situations. The fourth step is the implementation of access control. The policies of Identity and Access Management (IAM) are used to: Authentication of users is required. Role-based resource authorization. Monitor login behaviour Limit suspicious behaviour.

4.4 **Threat Simulation and Testing**.

Effectiveness of security is checked by

Modelling

Insider threats (access by unauthorized employees)

Unauthorized logins (external attacks).

Attempts of privilege escalation.

System responses are studied to determine the effectiveness of Zero Trust.

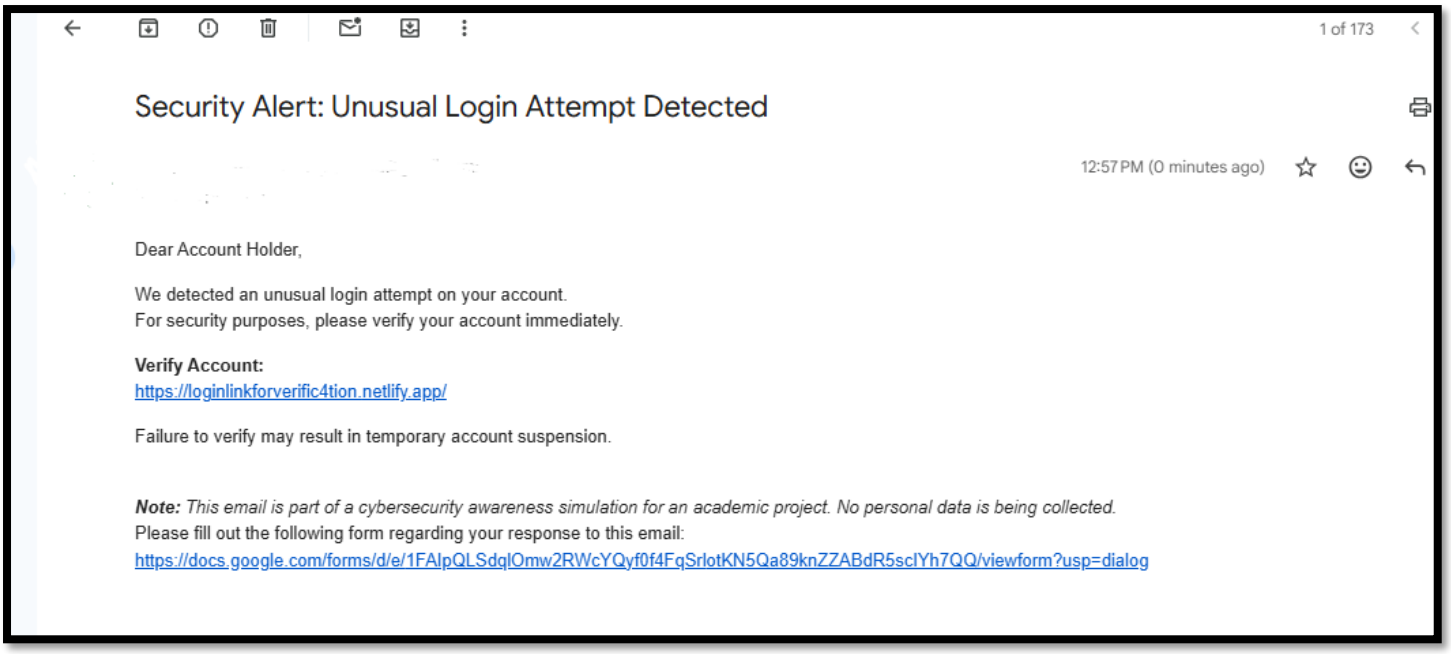
5. Phishing Email Design

A phishing email template was created to resemble a legitimate security notification so that it could be used to simulate a phishing attack situation. The aim of the email was to set a real life scenario where the users would have an urge to see the urgency to check their account details.

The email was well formatted in such a way that it gave an impression of the kind of emails that are normally sent by online services when some suspicious activities are identified. It contained a subject line with an emergency and a brief message that said that the account of the user had to be verified.

Urgency and authority were other social engineering methods in the email to enhance the potential of users to act swiftly without seeking to determine whether the message is genuine or not.

This design evidences that attackers usually turn on human psychology to mislead users to click on malicious links or even input valuable information.



1 of 173

Security Alert: Unusual Login Attempt Detected

12:57 PM (0 minutes ago)

Dear Account Holder,

We detected an unusual login attempt on your account.
For security purposes, please verify your account immediately.

Verify Account:
https://loginlinkforverific4tion.netlify.app/

Failure to verify may result in temporary account suspension.

Note: *This email is part of a cybersecurity awareness simulation for an academic project. No personal data is being collected.*
Please fill out the following form regarding your response to this email:
https://docs.google.com/forms/d/e/1FAIpQLSdqlOmw2RWcYQyf0f4FqSrlotKN5Qa89knZZABdR5sclYh7QQ/viewform?usp=dialog

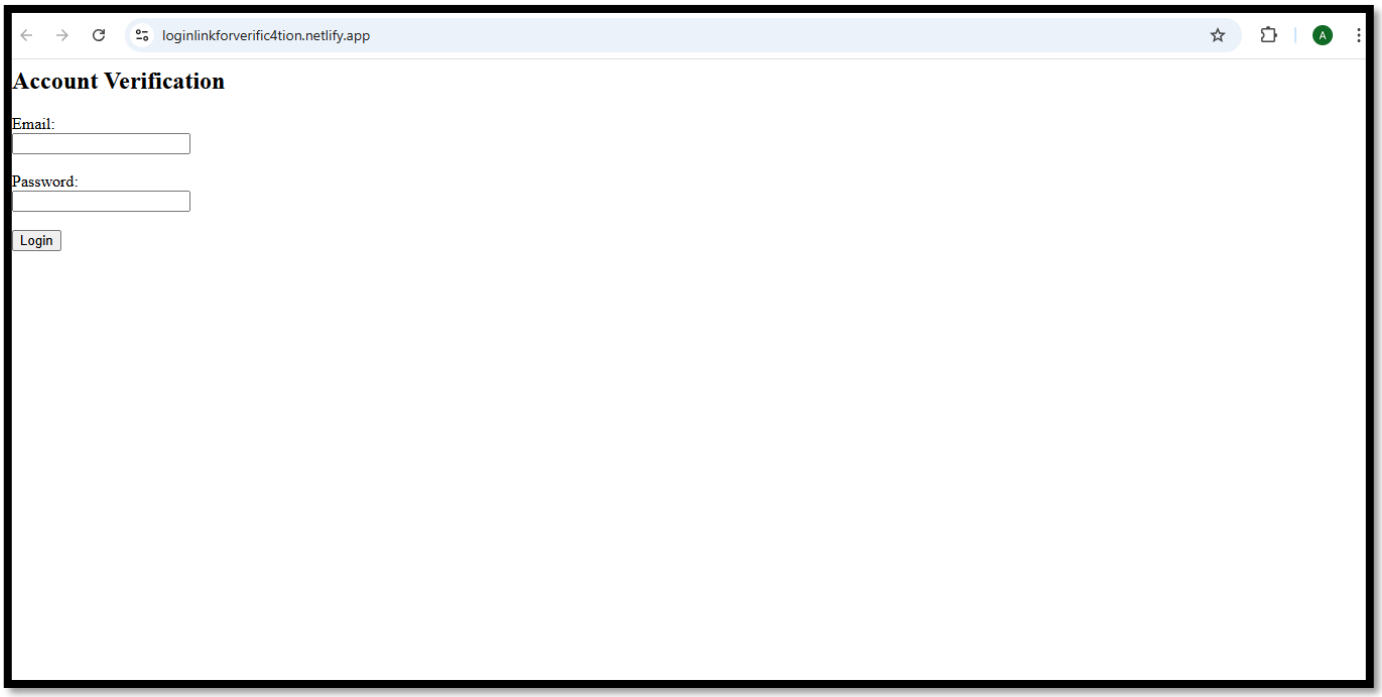
6. Fake Login Page Design

A fake login webpage was developed with simple web development technologies to recreate the scenario of a realistic phishing attack. This page was meant to imitate an official login portal, which may be used by the users to confirm their accounts over the internet. It was created in HTML and simple styling with a web hosting platform that was used to host the webpage in order to render it available as a link on the phishing email.

The elements used in the login page were the input field of email, a password field and the login button among others, which are usually used. The layout of the site was kept deliberately minimal and realistic to show how the phishing websites tend to replicate the authentic login portals.

Attackers are often guilty of using such fake pages to defraud users into entering their login credentials without understanding that the site is a malicious one. There was no actual user credential stored or collected in the log-in page in this project.

The page was designed just to show how phishing sites work and investigate how people behave when they are shown such login forms. The page had a login button that directed the users to a survey form in which they were required to answer how they reacted to the phishing email and whether they suspected that the page was a fraud.



7. Experiment Results

The phishing awareness exercise was carried out among 7 participants. The aim of the experiment was to determine the reaction of the users when a suspicious email with a verification link was received.

The participants were also requested to communicate with the email in a real way and then fill a survey explaining how they responded and how they understood the message.

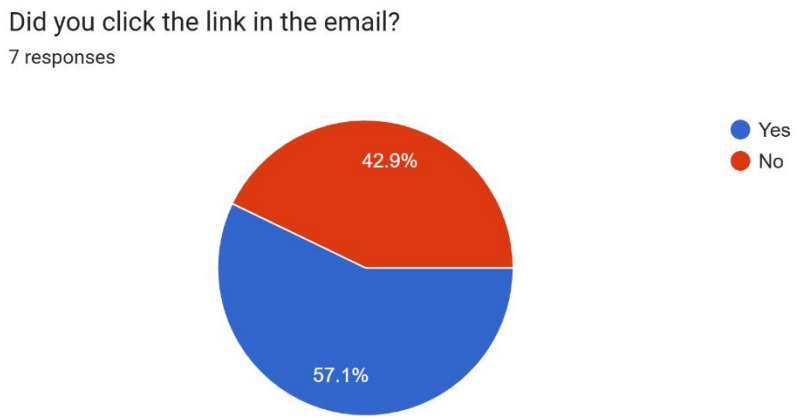
User Action	Number of Participants
Clicked the link in the email	4
Did not click the link	3
Thought the email looked legitimate	4
Thought the email looked suspicious	3

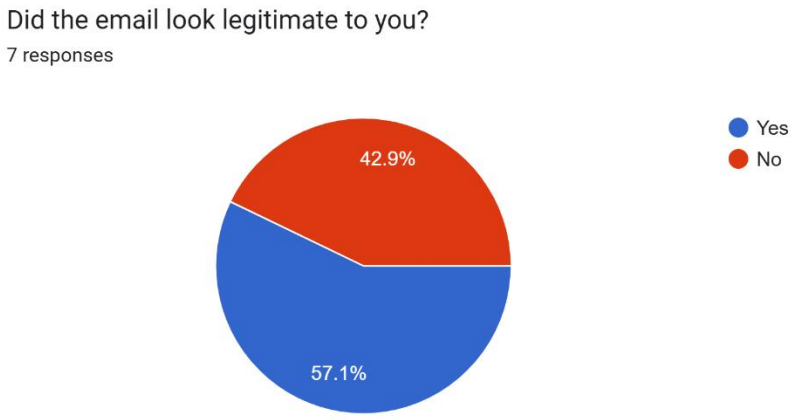
User Action	Number of Participants
Would normally enter login credentials	1
Would not enter credentials	6
Recognized phishing attempt	5
Did not recognize phishing attempt	2

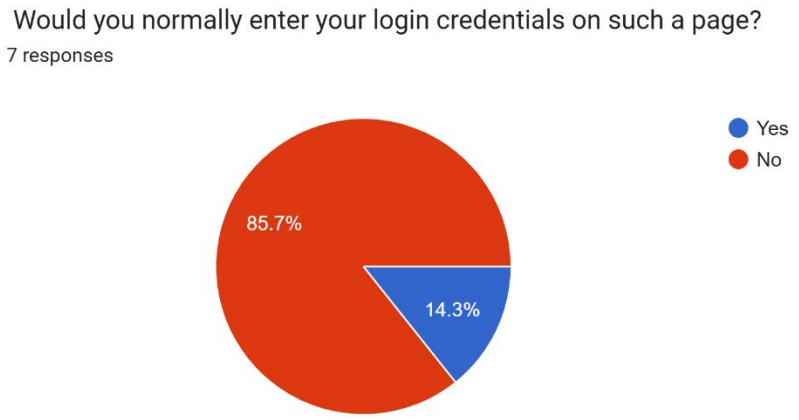
The outcomes have shown that over 50 percent of the respondents have clicked on the verification link, which proves the effectiveness of phishing emails that seem to be associated with supporting account security among users. Also, four of the participants have thought that the email was real at first, and this indicates how persuasive phishing messages can sound when they resemble regular security messages.

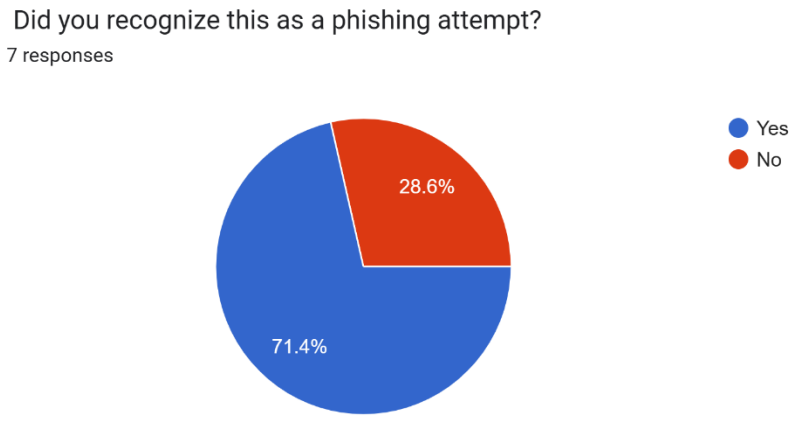
Nevertheless, the experiment also revealed that the majority of the participants were risk-averse to input their credentials because only one respondent said that he/she would usually give login details on such page.

Besides, 5 participants could identify the email as a phishing attempt, indicating that there is some degree of cybersecurity awareness among the participants. These results indicate that cybersecurity education and awareness training must be conducted continuously to assist users to detect and prevent phishing attacks.









8. Discussion

The outcomes of the phishing awareness simulation can be extremely useful to understand how users behave in case they receive suspicious emails. The experiment showed that phishing

emails could effectively draw the attention of the users, particularly when they cause a feeling of urgency regarding account security.

Four of the seven participants who received the phishing email in the simulation used the provided link in the message, which shows that the greater part of users is ready to deal with the message. This action underscores the fact that phishing attacks take advantage of human curiosity and worry about account security.

The other significant finding of the experiment was that four participants initially thought that the email was authentic. It means that phishing messages may seem convincing as they reproduce the format and style of official communications of organizations.

The results gave however, also revealed that the majority of participants were guarded in regards to the provision of sensitive information. It is only one participant who said that they would normally input the login credentials on such a page which would indicate that the participants have a certain degree of awareness on online security.

Moreover, 5 participants could identify the email as a phishing email, which means that cybersecurity education and previous knowledge of phishing email can assist users in spotting suspicious emails.

Some of the reasons why the email made the users suspicious were also identified in the responses obtained on the participants. Other participants noted that they had observed suspicious links, email format that they had never attempted and information that was not well described in the message. These factors assisted them in marking the email as a possible phishing message.

On the whole, the findings prove that although a certain percentage of users can find phishing attempt, a significant number of people respond to suspicious emails. This reveals a sense of how vital cybersecurity awareness training and education is to enable users be aware and prevent phishing attacks.

9. Preventive Measures

Phishing attacks have remained one of the greatest security threats in cybersecurity since the attackers do not capitalize on technical issues but, instead, on human behavior. Nevertheless, a number of preventive measures may be taken to minimize the chances of becoming a victim of phishing attacks.

1. User Awareness and Training

Education of users on popular phishing methods is one of the best methods of preventing phishing attacks. Organizations are advised to engage in regular cybersecurity awareness to make employees detect suspect email, links, and attachments.

2. Verifying Email Sources

The user must never trust email addresses of the sender and must never follow any links or attachments without verifying the email address of the sender. Phishing emails have addresses that seem to belong to legitimate organizations and have minor differences or peculiar domains.

3. Do not Click on Untrustworthy Links

Email users are not to open links in emails which require some urgent actions like passwords resetting or account verification. Rather, they can go to the official site of the organization manually to verify the request.

4. Multi-Factor Authentication (MFA) is used

The multi-factor authentication will provide an extra security measure because after entering a password, users will be required to confirm their identification through various means like a password and a one-time verification code. This minimizes the chances of unauthorized access in case there is a breach of login credentials.

5. Email Security and Mail Filters

Email filter systems and security software help organizations to identify and block phishing emails before they reach the users. The modern email security systems are able to detect suspicious links, attachments and sender addresses.

6. There is a report section where one can report on Suspicious Emails

Users must notify their IT or security department of suspect emails to their organization. Reporting phishing cases also assists an organization to detect threats and respond to such cases appropriately to avoid subsequent attacks.

Such prevention steps will go a long way to mitigating the threat of phishing audits and enhance the general cyber-awareness among consumers.

10. Conclusion

The phishing attacks have been one of the most prevalent and efficient types of cybercrime since they take advantage of the human factor instead of technical vulnerabilities. In social engineering, urgency, fear, and impersonation are some of the techniques that attackers apply to deceive users to divulge sensitive information.

This project was designed to recreate a phishing situation under conditions that are controlled to gain an insight into how people react to suspiciously sent emails. To resemble a regular account verification email, a phishing email and a spores fake login page were designed. The small group of participants was used to conduct the simulation and to gather the response in the form of a survey.

The findings of the experiment revealed that some of the participants took part in the phishing email by clicking on the verification link. It shows that phishing messages can sometimes effectively grab the user interest when it is made to seem like an account security issue.

Nevertheless, the majority of the participants were cautious about providing their credentials and many could identify the e-mail as a phishing attack.

The results contribute to the relevance of cybersecurity awareness and user education to prevent phishing attacks. Being able to comprehend the mechanics of phishing and being aware of the most typical warning signals, a user may minimize the chance of falling prey to these activities.

In general, the given project proves that phishing simulations are a great educational tool that might be used to enhance cybersecurity awareness and promote safer and more responsible online behaviour.

References

1. National Institute of Standards and Technology (NIST). (2020). *Digital Identity Guidelines and Security Practices*. U.S. Department of Commerce.
2. Verizon. (2023). *Data Breach Investigations Report*. Verizon Enterprise.
3. Hadnagy, C. (2018). *Social Engineering: The Science of Human Hacking*. Wiley Publishing.
4. Microsoft Security Team. (2022). *Phishing Protection and Email Security Guidelines.*
5. Cisco Systems. (2022). *Email Security and Phishing Defense Strategies.*
6. Cloudflare. (2023). *Understanding Phishing Attacks and How to Prevent Them.*